



Ko'chatim

Greenhouse Management System

Seedling Inventory · Sales · Partners · Analytics

Transforming how greenhouse gardeners manage their business

A full-stack platform connecting Telegram Bot,
Web Dashboard, and REST API — all in one unified system.

Web App

Telegram Bot

REST API

Challenges Facing Seedling Gardeners Today

Without digital tools, greenhouse operations rely on fragile manual processes



Manual Inventory Tracking

Gardeners use paper notebooks or memory to track seedling counts across dozens of varieties — leading to costly errors and overselling.



No Sales Analytics

Sales data is scattered across receipts and memory. There's no way to see which seedlings sell best or track revenue over time.



Partner Collaboration Gaps

Sharing inventory or coordinating with fellow gardeners requires phone calls and manual cross-checking — slow and error-prone.



No Mobile-First Solution

Existing farm software is desktop-only or too complex. Gardeners need a simple tool they already know — like Telegram.



Security & Access Control

Shared spreadsheets have no access control. Anyone with the link can edit data, and there's no audit trail of who changed what.



Multi-Grade Inventory Chaos

Seedlings come in 3 quality grades. Tracking grade-1, grade-2, and grade-3 stock separately is nearly impossible without software.

Ko'chatim — One Platform, Every Need

A unified ecosystem that meets gardeners where they already are — Telegram and the web



Telegram Bot

- Onboarding via phone number
- Add inventory by chat
- Record sales in seconds
- Partner invite deep-links
- OTP code delivery



Web Dashboard

- Real-time inventory view
- Sales history & pie charts
- Partner management
- Active session control
- Dark / Light theme



REST API Backend

- Flask + PostgreSQL
- Session & API-key auth
- 60-second cache layer
- Parallel DB queries
- ImgBB image hosting

How Everything Connects

 User*→ opens* Telegram App*→ updates* Telegram Bot
(Aiogram 2.x)*→ REST / API Key* Web Browser*→ opens* Mini App / React
(kochatim.uz)*→ REST / Token* Flask REST API Backend

Session Auth · API Key Auth · CORS · Connection Pool

→ SQL PostgreSQL



Smart Inventory

3-grade stock tracking (quality 1/2/3) per variety. Real-time updates. Negative-stock prevention. Full change log.



Sales Tracking

Record sales via Telegram in one step. Auto-deducts from stock. Visual pie charts by category. Full history.



Partner Network

Generate 7-day invite tokens. Accept/decline via bot. View partner's public inventory. Symmetric bidirectional links.



Secure Sessions

Max 3 active sessions per user. Remote logout from any device. OTP via Telegram. SHA-256 token hashing.



Live Analytics

Dashboard with 60-second cache. 5 parallel DB queries. Pie charts, sales summary, category breakdown.



Telegram-First UX

Onboard with phone share. Auto-login via Mini App. Deep-link partner invites. No app download needed.

Two Secure Login Paths

Path A — OTP Login (Phone + Telegram)

1

User sends /start to bot

Bot prompts phone share

2

Bot calls POST /auth/request-code

Backend generates 6-digit OTP

3

OTP sent via Telegram message

SHA-256 hash stored — not plaintext

4

User enters code on web site

POST /auth/verify-code

5

Session token issued (32 bytes)

Token hash stored in DB, token sent to client

6

Stored in localStorage

Max 3 sessions — oldest auto-revoked

Path B — Telegram Mini App Auto-Login

1

User opens bot → taps Web App button

Opens kochatim.uz inside Telegram

2

Mini App calls tg.ready() + tg.expand()

Full-screen Telegram WebApp

3

Reads
`window.Telegram.WebApp.initData`

Telegram-signed user data

4

POST /auth/telegram-webapp

Server verifies HMAC-SHA256 signature

5

Session token issued instantly

No OTP needed — seamless login

6

Redirect to /dashboard

is_registered check — onboard if needed

Frontend

React 19

Component-based UI, fast state management

Vite 6

10-20× faster than CRA for build & dev

Recharts

SVG-based pie charts, React-native API

Sass / SCSS

Variables, nesting, and design tokens

React Router 7

URL → component mapping, protected routes

Backend

Flask 3.0

Micro-framework — only what is needed

PostgreSQL

SERIAL, RETURNING, lateral JOINS, no lock issues

Psycopg2 Pool

Reuse connections, skip 150-300ms overhead

Gunicorn

Multi-worker WSGI for production

python-dotenv

Secrets out of code and into .env

Bot & Infra

Aiogram 2.x

Async Telegram bot with FSM state machines

ImgBB

Free image hosting via base64 API

ip-api.com

Free geolocation for session city display

HMAC-SHA256

Telegram initData verification (bot token)

In-process Cache

60-second TTL avoids repeated DB hits

Defense-in-Depth Security Model

Multiple independent layers ensure user data stays safe even if one layer is breached



OTP Hashing

SHA-256 hash

The 6-digit OTP is never stored — only its SHA-256 hash is persisted. If the database leaks, the plaintext code remains unknown.



Token Hashing

SHA-256 hash

Session tokens are stored as hashes. Stolen DB rows cannot be used to impersonate a logged-in user.



Timing Attack Guard

`hmac.compare_digest`

All secret comparisons use `hmac.compare_digest()` which runs in constant time, blocking side-channel timing attacks.



Telegram Verification

HMAC-SHA256

Telegram Mini App initData is verified with HMAC-SHA256 using the bot token. Forged logins are impossible without the secret.



SQL Injection Shield

%s placeholders

Every database query uses psycopg2 parameterized queries (%s). String interpolation into SQL is never used anywhere.



CORS Whitelist

Allowed origins

Only `kochatim.uz`, `app.kochatim.uz`, and `localhost:5173` may send credentialed requests. Other origins are rejected.



Session Limit

Max 3 sessions

A user can have at most 3 concurrent sessions. Creating a 4th auto-revokes the oldest — preventing unbounded token accumulation.



Ownership Check

`u_id` verification

Sales and inventory mutations verify that the seedling variety belongs to the requesting user before any write occurs.

End-to-End User Journeys



OTP Login Journey

1

User → /start in bot

2

Bot → POST /auth/request-code [API Key]

3

Backend → OTP hash stored → code sent to user

4

User → enters code on kochatim.uz

5

Web → POST /auth/verify-code

6

Backend → session_token issued → localStorage



Dashboard Load Journey

1

React App mounts → DashboardContext.fetchDashboard()

2

GET /api/me/dashboard [Bearer token]

3

60-second cache check → hit: instant return

4

Cache miss: 5 parallel DB queries via ThreadPoolExecutor

5

→ user · categories · types · seedlings · sales

6

JSON merged → cached → sent to client

7

All pages (Dashboard, Inventory, Sales) read from context



Performance: Sequential 5-query latency ~150ms → Parallel execution brings it to ~50ms



Generate Invite

Gardener A clicks 'Add Partner' in web settings. A one-time token is created (valid 7 days). A shareable Telegram deep-link is returned: `t.me/kochatim_bot?start=partner_TOKEN`



Share the Link

Gardener A sends the link to Gardener B via any channel. B clicks the link, which opens the Telegram bot with the partner token embedded in the `/start` payload.



Accept or Decline

The bot detects the `partner_` prefix and presents Accept / Decline buttons. B's choice is sent to `POST /api/partners/accept` or `/decline` via the API key.



Link Established

On accept: two symmetric rows are inserted — (A, B) and (B, A). Both users receive a Telegram confirmation. On decline: token is discarded, no changes occur.



View Partner Inventory

Each partner can browse the other's public dashboard at `/gardeners/:u_id` — seedling stock, categories, and types — without needing login.

users

TABLE

Telegram ID, name, phone, username, age, profile photo URL

categories

TABLE

Seedling groups (e.g. Fruit Trees, Flowers) — owned by a user

types

TABLE

Varieties within a group (e.g. Apple – Fuji). Linked to a category

seedlings

TABLE

Stock counts per variety: quality_1, quality_2, quality_3

seedlings_logs

TABLE

Audit log of every inventory change — who, when, how much

img

TABLE

Images: ImgBB URL or Telegram file_id, linked to a variety

sales

TABLE

Sales records: variety, quantity sold, price, timestamp

login_codes

TABLE

OTP codes stored as SHA-256 hash with TTL and used-flag

sessions

TABLE

Active sessions: token hash, device name, IP, city, expiry

partners

TABLE

Symmetric partner pairs: (A→B) and (B→A) stored as two rows

partner_invites

TABLE

One-time invite tokens: 7-day expiry, single-use flag



Ko'chatim
Ko'chatim

From Paper to Platform

What Ko'chatim Delivers

- ✓ Real-time 3-grade inventory with full change history
- ✓ Sales recording in one Telegram message
- ✓ Pie-chart analytics — category breakdown at a glance
- ✓ Partner network with secure 7-day invite tokens
- ✓ Dual auth: OTP + Telegram Mini App auto-login
- ✓ SHA-256 token hashing, CORS whitelist, timing-safe compare
- ✓ 5-parallel-query dashboard cached for 60 seconds
- ✓ Remote session management from any device